Report Summary for Precious Healthcare

A cybersecurity threat, vulnerability, and risk analysis was performed at Precious Healthcare Center, which is a hypothetical organization located in Grand Rapids, Michigan, used in this project to practice risk analysis through a self-directed assessment. Based on the results of the analysis, the following three risks were found to be the top three, each scoring 20 out of 25, that can lead to compromised information in the organization:

1. **Emails:** Due to a lack of staff training and no use of fraudulent email detection systems, the risk of phishing scams is high in the organization right now. This can lead to a staff member clicking on a phishing email and compromising both patient and organizational information.
2. **Patient details:** The passwords used by the clinic are not strong enough, and the use of common passwords is seen across different departments of the center. Not only that, there is no MFA implemented in any of these departments to access the information by the staff members. Moreover, the website used by the organization is vulnerable and not secure enough to protect information and can be penetrated easily by an attacker. This can lead to serious crimes like identity theft or misuse of information. A breach of patient data could also lead to HIPAA penalties; therefore, the risk of compromised patient details (by an insider or outsider) is high in this case.
3. **Computers:** There is no recovery backup plan or strategy in case the computers are attacked by malware, so if an attacker targets systems within the organization, data can be lost easily. Also, no malware detection systems or firewalls are currently used, & no encryption making it worse.

Recommended controls to mitigate these risks:

1. **Administrative Control:** First and foremost, proper training for staff regarding phishing emails and other cybersecurity threats should be provided. They should be taught how an attacker can attack and penetrate the systems and what implications it can cause in a victim's life. The principle of least privilege should be followed, meaning staff should have access only to the resources necessary for their field. An independent access control policy should be implemented, allowing access to staff using their unique IDs.
2. **Logical or Technical Controls:** Strong and different passwords should be used by the staff of different departments. Authentication should be implemented. Implement strong data encryption and use firewalls and endpoint protection for organizational assets.

3. **Recovery and detection:** Proper backup plans and strategies should be made, along with the availability of backup devices in case an attack happens. Malware detection systems and email login alert systems should be implemented.